

Controls and compliance checklist

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☐	☒	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☒	☐	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☒	☐	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations:

“ According to the different sections reviewed for the company during the audit, there is a significant amount of controls that need immediate attention to which would improve the security posture of Botium Toys in regards to keeping compliant and abiding to current regulation.

- *applying least privilege and separation-of-duties controls make sure that everyone has access to only the resources they need to get their work done. This can reduce the attack surface through all networks and systems of the company.*
- *Better use of disaster recovery plans and backups of critical data minimize the downtime and aid in business continuity; make sure these are also regularly updated.*

- *All user accounts require very strong passwords of considerable length and characters as this greatly decreases the risk of user accounts being hijacked, sabotaged or compromised, leading to even further risks; a password management system will be useful in prompting users to change their passwords if they are weak.*
- *I would also highly suggest some fire safety and precautions taking into account the valuable items and toys the company's main income comes from merchandise; sprinklers and fire alarms can reduce any damage from potential fires.*